

Figure 4: Details in the SAST report

Figure 5: Downloadable HTML report for SAST using Snky

Post-build actions: Select **Publish HTML reports** and change the name of the report to **result.html**.

Save and build the project. An HTML report can be found, as depicted in Figure 5.

Download the HTML report from this location. The report includes all the important information like the vulnerabilities, their severity, bad dependencies, origin, remediation, and references, as shown in Figure 6.

SAST with SonarQube

Another tool we are discussing is SonarQube. It is a self-activating code review tool for ascertaining vulnerabilities, bugs and code smells in the project code. For its installation, we will use a Docker image of SonarQube.

Installing SonarQube server

1. The community edition Docker image of SonarQube is obtainable at https://hub.docker.com/_/sonarqube/.
2. Establish the server by executing the command given below:

```
$ sudo docker run -d --name sonarqube
-p 9000:9000 <image_name>
```

3. Open SonarQube accessible at <http://localhost:9000> using your browser, and log in with systems administrator identifiers. The default user name and password is 'admin'. After a successful login, the *SonarQube Projects* page will open, from where you can create a new project or open an existing one.

Analysing a Java/Maven project

Follow these steps to analyse a Java/Maven project: